

365CMS Technical Audit Report

****Audit-Datum:**** 2026-06-12

****Scope:**** D:\00-WPwork\365CMS.DE

****Methodik:**** Lokale Struktur-, Konfigurations- und Codeanalyse der 365CMS-Codebasis.

Drittanbieter-/Backup-/Asset-Verzeichnisse wurden für Zählungen erfasst, für First-Party-Findings jedoch fokussiert gefiltert. Keine Secrets wurden ausgegeben.

Executive Summary

Der technische Gesamtscore beträgt **76/100**. 365CMS wirkt funktionsreich und enthält mehrere belegbare Schutzmechanismen (CSRF, Security Header, Upload-Prüfungen, Syntax-saubere PHP-8.4-Ausführung im fokussierten Scope). Die größten Risiken liegen in Wartbarkeit/Dependency-Governance, Upload-/Import-Angriffsfläche, dynamischen SQL-/Maintenance-Pfaden, Performance bei Vollbestandsoperationen und fehlender zentral sichtbarer CI-/Dependency-Pipeline.

Inventar-Zusammenfassung

ID	Typ	Name	Beschreibung/Zweck	Relevante Dateien	Einstiegspunkt/Aufrufpfad	Abhängigkeiten	Audit-Relevanz	Quelle
---	---	---	---	---	---	---	---	---
MOD-CORE	Modul	Core Runtime	Bootstrap, DB, Routing, Auth, Services	CMS\core, CMS\includes, CMS\index.php	Frontcontroller/Bootstrap	PDO, Security, Services	sehr hoch	Codefund
MOD-ADMIN	Modul	Admin UI	Dashboard und Fachmodule	CMS\admin\modules, CMS\admin\views	CMS\admin\index.php	Core, DB, Security	sehr hoch	Codefund
MOD-MEDIA	Modul	Media Library	Uploads, Metadaten, EditorJS	CMS\admin\modules\media, CMS\core\Services\Media, CMS\core\Services\EditorJs	Admin/EditorJS Uploads	FileUploadService, MediaService	sehr hoch	Codefund
MOD-SEO	Modul	SEO	Sitemap, Meta, Analytics, Performance	CMS\admin\modules\seo, CMS\core\Services\SEO, CMS\core\Services\SitemapService.php	Admin SEO, Frontend	DB, Theme, Settings	hoch	Codefund
MOD-LEGAL	Modul	Legal/Consent	Cookie-Kategorien, Services, Tracking Consent	CMS\admin\modules\legal	Admin Legal, Frontend Consent	Settings, SEO Analytics	hoch	Codefund
MOD-MEMBER	Modul	Member Area	Member Dashboard, Uploads, Auth-abhängige Funktionen	CMS\member, CMS\admin\modules\member, CMS\core\Member	Member/Admin	Auth, Media	hoch	Codefund
MOD-IMPORTER	Plugin	CMS Importer	WXR/RankMath Import	CMS\plugins\cms-importer	Plugin Admin Upload	Uploads, XML/JSON Parser	hoch	Codefund
MOD-THEME	Modul	Default Theme	Frontend Templates, Sidebar, Tagcloud	CMS\themes\cms-default	Frontend Render	DB, Theme helpers	mittel	Codefund
MOD-INSTALL	Modul	Installer	Erstinstallation/Konfiguration	CMS\install, CMS\install.php	Web Installer	Config, DB	hoch	Codefund
MOD-CRON	Modul	Cron	Web/CLI Jobs	CMS\cron.php	CLI/Web Cron	Token, HTTPS Detection	mittel	Codefund
CFG-WEBSERVER	Konfiguration	Apache .htaccess	Security Header, CSP-Fallback, HSTS	CMS\.htaccess, CMS\config\.htaccess	Apache Request	mod_headers	hoch	Konfigurationsfund
TESTS	Test	Modulnahe Tests	Tests für Media, SEO, Router, Runtime etc.	TESTS*	nicht zentral erkennbar	PHP/Test Runner unklar	mittel	Konfigurationsfund/Heuristik

Score-übersicht je Bereich

Bereich	Score
---	---
Sicherheit	72
Bugs und Stabilität	78
Performance	74
SEO	82
PHP 8.4 Best Practice und Kompatibilität	80

Funktionsvollständigkeit	76
Unvollständige Implementierungen	75
Wartbarkeit	68
Gesamt	**76**

Score-Übersicht je Modul/Feature/Funktion

Ebene	ID	Score	Begründung
Modul	MOD-CORE	77	Core ist strukturiert, aber generische Query- und Maintenance-Pfade erhöhen Risiko.
Modul	MOD-ADMIN	74	Viele Module und direkte Request-Zugriffe; CSRF-Strukturen vorhanden.
Modul	MOD-MEDIA	72	Funktional umfangreich, Upload-Angriffsfläche bleibt hoch.
Modul	MOD-SEO	82	SEO-Services vorhanden, Performance/Alt-Text-Gates ausbaufähig.
Modul	MOD-LEGAL	80	Consent-/Placeholder-Logik vorhanden, Validierungsstatus ausbaufähig.
Modul	MOD-MEMBER	76	Member-Funktionen vorhanden, Upload-Feature konfigurationsabhängig.
Modul	MOD-IMPORTER	70	Import-Uploads und Parser-Flows sind risikoreich.
Modul	MOD-THEME	78	Theme funktioniert, enthält aber performancerelevante direkte DB-Aggregation.
Modul	MOD-INSTALL	79	Installer vorhanden, Prozessabbrüche/Runtime-Kopplung mindern Testbarkeit.
Modul	MOD-CRON	76	CLI/Web Cron vorhanden, Query-Token-Fallback bleibt Schwachpunkt.
Feature	Datei-Uploads	70	CSRF/MIME vorhanden, aber große Angriffsfläche.
Feature	Datenbankzugriff	75	Prepared APIs existieren, generische Query-API bleibt Wartbarkeitsrisiko.
Feature	Backup/Wartung	72	Vollbestandsoperationen und synchrone DB-Wartung.
Feature	Sitemap/SEO	82	Mehrere Services vorhanden, Konsistenztests empfohlen.
Funktion	Web-Cron Token	76	Header und Query werden akzeptiert; Query-Fallback deprecated behandeln.
Funktion	Tagcloud	70	Vollscan über Tags in PHP.
Funktion	Alt-Text-Normalisierung	82	Normalisierung vorhanden, Pflicht-/Qualitätsgate fehlt.

Risiko-Übersicht

Schweregrad	Anzahl
kritisch	0
hoch	7
mittel	22
niedrig	7

Diagramm: Bereichsscores

```
““text
Sicherheit 72 | #####
Bugs/Stabilität 78 | #####
Performance 74 | #####
SEO 82 | #####
PHP 8.4 80 | #####
Funktionsvollständigkeit 76 | #####
Unvollständige Implementierungen 75 | #####
Wartbarkeit 68 | #####
““
```

Top-Findings

ID	Schweregrad	Bereich	Beschreibung	Fundstelle
MAINT-001	hoch	Wartbarkeit	Vendor Dependencies, Backups und Artefakte liegen im Repository-Scope.	ASSETS, BACKUP, CMS\assets, CMS\vendor
SEC-001	hoch	Sicherheit	Upload-/Import-Flows sind eine zentrale Angriffsfläche.	

FileUploadService.php, UploadHandler.php, cms-importer class-admin.php |
| SEC-002 | hoch | Sicherheit | Dynamische SQL-Wartungsbefehle h?ngen an Identifier-Validierung. |
CMS\core\Services\SystemService.php:611-617 |
| PERF-001 | hoch | Performance | BackupService erzeugt vollst?ndige DB-Dumps im PHP-Prozess. |
CMS\core\Services\BackupService.php:278-303 |
| PHP84-001 | hoch | PHP 8.4 | Kein zentrales Root-/CMS-Composer-Manifest/Lockfile gefunden. |
Repository-Konfiguration |

Priorisierte Roadmap

1. **P1:** Dependency-/Artifact-Governance einf?hren: Composer/NPM-Metadaten, SBOM, Lockfiles, Drittbibliotheken und Backups aus dem Quellscope trennen.
2. **P1:** Upload-/Import-Sicherheitsmodell zentralisieren: Kontext-Allowlists, Quarant?ne, Content-Scan-Hook, Retention.
3. **P1:** SQL-Identifier-/Maintenance-Pfade h?rten und 'Database::query()' aus Fachmodulen zur?ckdr?ngen.
4. **P2:** Backup, Tagcloud und Systemwartung auf Chunking/Jobs/Caching umstellen.
5. **P2:** Zentrale CI-/Test-Pipeline mit PHP-8.4-Deprecation-Gate und Modul-Smoke-Tests definieren.
6. **P2:** Request-DTO-/Validator-Layer einf?hren und direkte Superglobal-Nutzung schrittweise reduzieren.

Quellen-/Evidenzklassifizierung

- **Codefund:** konkrete Datei-/Zeilenfunde in CMS\core, CMS\admin, CMS\plugins, CMS\themes.
- **Konfigurationsfund:** .htaccess, fehlende Root-/CMS-Manifeste, vendored Dependency-Struktur.
- **Heuristik:** Bewertung von Gr??e, Kopplung, Test-/Pipeline-Sichtbarkeit ohne vollst?ndige Laufzeitumgebung.
- **Externe Best Practice:** Nicht als eigene Quelle markiert, da dieser automatisierte Lauf keine Web-Recherche ben?tigte/ausf?hrte; Empfehlungen folgen etablierten Security-/Performance-/SEO- und PHP-8.4-Praktiken, sind hier aber als Heuristik dokumentiert.

Validierung

- Pflichtbereiche abgedeckt: Sicherheit, Bugs/Stabilit?t, Performance, SEO, PHP 8.4, Funktionsvollst?ndigkeit, unvollst?ndige Implementierungen, Wartbarkeit.
- PHP-Syntaxpr?fung: 498 fokussierte First-Party-PHP-Dateien, 0 Syntaxfehler.
- Berichte erzeugt unter 'docs\audit' und PDF-Gesamtbericht im Repository-Root.
- Verdachts-/Heuristik-Aussagen sind als solche gekennzeichnet; keine Secrets wurden ausgegeben.